

ISO AI Standards

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 26: Compliance Frameworks and Standards

1. The Three-Layer AI Governance Stack

Before diving into the technical details of individual standards, it helps to situate ISO/IEC AI standards within the broader governance landscape. Think of AI governance as three stacked layers. The top layer is law — binding legal instruments such as the EU AI Act that specify what outcomes organizations must achieve, backed by regulatory enforcement and financial penalties. The middle layer is frameworks — structured but voluntary guidance like the NIST AI RMF 1.0 that provides a conceptual model for how to think about AI risk without mandating specific controls. The bottom layer is standards — the ISO/IEC technical specifications produced by JTC 1/SC 42 that define how to build the operational machinery that makes compliance real.

The critical insight is that standards operate below frameworks and laws: they translate abstract requirements into concrete implementation specifications. Organizations that understand only the top two layers know what they need to do and roughly how to think about it. Those that also master the standards layer know precisely how to do it — and can demonstrate conformity to external auditors, regulators, and customers. ISO/IEC 42001 does not duplicate the EU AI Act or NIST AI RMF; it operationalizes them.

Key distinction: Laws specify required outcomes. Frameworks organize thinking. Standards specify implementation. The EU AI Act tells you what. NIST AI RMF 1.0 tells you how to think. ISO/IEC 42001 tells you how to build it.

2. ISO/IEC 42001:2023 — The First Global AIMS Standard

ISO/IEC 42001:2023 is the landmark document in AI governance standardization: the first international standard specifying requirements for an Artificial Intelligence Management System (AIMS). Published in December 2023 by the Joint Technical Committee JTC 1/SC 42 — a collaboration between ISO (International Organization for Standardization) and IEC (International Electrotechnical Commission) — it applies to any organization that develops, provides, or uses AI products and services.

The management system model is important to understand through analogy. ISO/IEC 27001 does not specify which firewall vendor to use — it specifies that organizations must identify information security risks and implement controls to address them. Similarly, ISO/IEC 42001 does not specify which algorithm to use or what accuracy threshold a model must meet. It specifies that organizations must conduct AI system impact assessments, implement human oversight mechanisms, manage data quality for training, and maintain governance structures for AI decisions. The standard creates the management envelope; the organization fills it with technically appropriate controls.

Organizations can be certified against 42001 by accredited third-party certification bodies, providing external assurance of their AI management practices. Certification is becoming a procurement

differentiator and, in some jurisdictions, a forthcoming regulatory expectation. The question for practitioners is not whether 42001 matters — it does — but how quickly organizations in their sector will face pressure to certify.

3. The Structure of ISO/IEC 42001: Seven Core Clauses

ISO/IEC 42001 follows the High-Level Structure (HLS) shared by all modern ISO management system standards. The HLS enables integrated implementation alongside ISO/IEC 27001 and ISO 9001 without redundant parallel systems, shared internal audit programs, and a single documented risk management process. Exam candidates who know ISO/IEC 27001's structure will recognize 42001's clause layout immediately.

Clause	Topic	What It Requires
4 — Context	Organizational context	Define the organization's role in AI, identify stakeholders and their expectations, scope the AIMS
5 — Leadership	Governance commitment	Top management commitment, AI policy, assigned roles including AI risk ownership
6 — Planning	Risk and objectives	AI risk and opportunity assessment, AI objectives, plans to achieve them
7 — Support	Enabling resources	Competence, awareness, communication, documented information
8 — Operation	AI system lifecycle	AI system lifecycle management, impact assessments, procurement controls
9 — Performance evaluation	Monitoring and review	Monitoring, measurement, internal audit, management review
10 — Improvement	Continual improvement	Nonconformity management, corrective action, continual improvement

4. Annex A Controls — Where 42001 Gets Specific

The normative Annex A of ISO/IEC 42001 lists 38 controls across nine domains. This is where the standard provides operational specificity. Practitioners implementing 42001 use Annex A as a control selection framework — selecting and applying controls based on the organization's AI activities and risk profile, documenting exclusions with justification in a Statement of Applicability (mirroring the SoA mechanism in ISO/IEC 27001).

Annex A Domain	Key Controls (Exam-Relevant)
AI policies	AI use policy, roles and responsibilities
Internal organization	Governance body, risk ownership, supplier management (A.2.4)
AI lifecycle	Lifecycle process, change management, decommissioning
Data for AI systems	Data acquisition, training data validation (A.7.4), lineage
AI system impact assessment	Pre-deployment impact assessment for consequential systems (A.6.1)
AI system risk management	AI-specific risk identification, analysis, and treatment

AI system security controls	Output monitoring and logging (A.8.4), adversarial input controls
Human oversight	Human oversight design for consequential AI decisions (A.9.1)
Transparency and explainability	Disclosure obligations, explainability requirements to affected parties

High-exam-relevance controls to memorize: A.6.1 (impact assessment before consequential AI deployment), A.7.4 (training data validation), A.8.4 (output monitoring and logging), A.9.1 (human oversight design), and A.2.4 (procurement and supplier controls for third-party AI).

5. ISO/IEC 23894:2023 — The Risk Management Companion

Where ISO/IEC 42001 provides the management system requirements, ISO/IEC 23894:2023 provides the detailed risk management methodology. Aligned to ISO 31000 (the international risk management standard), 23894 gives practitioners a step-by-step process for identifying, analyzing, and treating AI-specific risks that traditional enterprise risk frameworks do not address.

AI-specific risks addressed in 23894 include: training data quality failures (corrupted, biased, or unrepresentative data producing unreliable model behavior); distributional shift (model performance degrading when real-world inputs diverge from training data distribution); adversarial inputs (deliberate manipulation of model inputs to produce incorrect outputs); emergent behavior (capabilities or failure modes not anticipated during training); interpretability failures (inability to explain model decisions to affected parties or regulators); and human-AI interaction risks (over-reliance, automation bias, failure of human override mechanisms).

23894 addresses risk across the full AI lifecycle — design, development, testing, deployment, monitoring, and decommissioning — and integrates with 42001's Planning (clause 6) and Operation (clause 8) requirements. Think of 23894 as the technical annex that gives operational content to 42001's risk management requirements.

6. Real-World Incident: Certification Scope and False Assurance

Samsung Semiconductor Data Leak (2023) — Certification Scope Lesson: Three separate Samsung employees transmitted proprietary semiconductor source code and internal meeting notes to ChatGPT within weeks of each other. No vulnerability was exploited; the sensitive data governance failure was that employees had no understanding of the data classification implications of inputting proprietary information into an external AI service. A company with an ISO/IEC 42001 AIMS covering supplier controls (A.2.4) and data classification requirements would have required a procurement review of ChatGPT before employee use, identified the data handling risk, and either prohibited use or implemented technical controls. Samsung's subsequent ban on generative AI tools on corporate devices is the reactive version of what 42001 operationalizes proactively.

The deeper certification lesson is about scope. An organization can achieve ISO/IEC 42001 certification for its internal AI development process while excluding third-party AI integrations from AIMS scope. This narrow scope provides regulatory optics without addressing the risks that matter most. When reviewing

any organization's 42001 certification, the critical question is: what AI systems are within scope, and which consequential AI activities have been excluded?

7. Framework Alignment: 42001 Mapped to CSF 2.0 and AI RMF

ISO/IEC 42001 maps cleanly to NIST CSF 2.0 and AI RMF 1.0, enabling organizations to build unified governance rather than parallel programs. Practitioners with CSF 2.0 implementations can identify which existing work products satisfy 42001 requirements.

ISO/IEC 42001 Requirement	NIST CSF 2.0 Function / Category	NIST AI RMF 1.0 Function
Clause 4: Context / Stakeholders	GV.OC — Organizational context	GOVERN
Clause 5: Leadership / Policy	GV.RM — Risk management	GOVERN
Clause 6: Planning / Risk Assessment	ID.RA — Risk assessment	MAP
Clause 8: Operation / Lifecycle	PR.PS — Platform security	MEASURE, MANAGE
Clause 9: Performance Evaluation	DE — Detect	MEASURE
Annex A.6.1: Impact Assessment	ID.RA — Risk assessment	MAP
Annex A.9.1: Human Oversight	GV.OV — Oversight	GOVERN
Clause 10: Improvement	RC — Recover	MANAGE

8. The JTC 1/SC 42 Standards Family — Know the Landscape

ISO/IEC 42001 and 23894 are the practitioner-critical standards, but they exist within a larger family. Practitioners should know which standard addresses which technical concern without memorizing every document's full content:

- ISO/IEC 22989:2022 — AI vocabulary and concepts. The 'dictionary' standard. Reference this when exam questions test terminology precision or ask about international AI terminology alignment.
- ISO/IEC 23053:2022 — Framework for AI systems using machine learning. Covers the ML system lifecycle and component relationships.
- ISO/IEC 24028:2020 — Trustworthiness in AI and addressing bias. A precursor to the trust and fairness dimensions codified in 42001.
- ISO/IEC 24029-1:2021 / 24029-2:2023 — Assessment of neural network robustness. Technical standards for testing model resilience to input variation and adversarial conditions.
- ISO/IEC 27090 (in development) — Cybersecurity and privacy of AI. Will provide AI-specific extensions to 27001's control framework when published.

9. EU AI Act Harmonized Standards and Presumption of Conformity

The EU AI Act specifies requirements for high-risk AI systems but delegates technical implementation to harmonized standards — the same mechanism used in CE marking and GDPR compliance. The European Commission has mandated CEN/CENELEC to develop these harmonized standards, with ISO/IEC JTC 1/SC 42 outputs as the primary technical input.

Once harmonized standards are published under the EU AI Act (expected 2025–2026), an AI provider demonstrating conformity with those standards benefits from a presumption of conformity with the Act's technical requirements. This means the standard does the compliance work: the organization implements 42001 (and its harmonized derivatives), obtains certification, and presents that certification as evidence of Act compliance — rather than needing to build a bespoke compliance case. Organizations implementing 42001 now are positioned to leverage this path rather than scrambling under regulatory pressure.

Exam shortcut — presumption of conformity: When an EU AI Act harmonized standard is satisfied, the provider benefits from a legal presumption of conformity with the corresponding Act requirements. ISO/IEC 42001 is the primary management system standard feeding these harmonized standards. Implementing 42001 now is the advance preparation strategy.

10. Red Team Perspective: Probing AIMS Boundaries

From an adversarial standpoint, ISO/IEC 42001 certification creates a new attack vector: relying on a certification that excludes material risks from scope. A red team or regulatory examination of a 42001-certified organization would probe:

- Scope completeness: Does the AIMS cover third-party AI components and external services used in production, or only internally developed models?
- Supplier controls (A.2.4): Are third-party AI vendors subject to procurement review before integration? Are their security and data governance practices contractually required?
- Impact assessment evidence (A.6.1): Can the organization produce documented impact assessments for all AI systems affecting customers — or only for systems the team decided to assess?
- Post-certification drift: Has the scope of AI deployment expanded since certification without triggering updated impact assessments or supplier reviews?
- Implementation vs. documentation: Do documented procedures reflect actual operational practice, or were they created for the audit?

The defense against these probe vectors is broad scope definition, operational embedding of AIMS controls in real workflows, and surveillance audit programs that test control operation rather than documentation existence.

11. Implementation Roadmap: Gap Assessment to Certification

For practitioners advising organizations on 42001 implementation, a five-phase roadmap is standard:

- Phase 1 — Gap assessment: Compare current AI governance practices against 42001 requirements and Annex A controls. Identify missing policies, undocumented processes, and absent controls. This phase reveals scope decisions and resource requirements.
- Phase 2 — Scope definition: Determine which AI systems and organizational activities fall within the AIMS boundary. Broad scope provides more assurance; narrow scope may exclude material risks. Scope decisions made here constrain all subsequent phases.

- Phase 3 — AIMS design: Develop policies, procedures, and documentation structures satisfying each clause. Integrate with existing 27001 or 9001 structures where the HLS allows shared clauses.
- Phase 4 — Implementation and operation: Operationalize the AIMS across AI development, procurement, and deployment activities. Most organizations struggle here — paper systems that are not reflected in real decisions create major nonconformities at Stage 2 audit.
- Phase 5 — Certification audit: Stage 1 (documentation review by accredited certification body) followed by Stage 2 (on-site implementation audit). Typical timeline: 9–18 months from gap assessment to certification.

Key Terms Glossary

Term	Definition
ISO/IEC 42001:2023	The first international standard specifying requirements for an Artificial Intelligence Management System (AIMS); enables third-party certification.
AIMS	Artificial Intelligence Management System — the organizational structure, policies, processes, and controls that govern AI activities as defined in ISO/IEC 42001.
JTC 1/SC 42	The joint ISO/IEC technical committee responsible for producing AI standards; the subcommittee on artificial intelligence.
ISO/IEC 23894:2023	Guidance standard for AI risk management, providing a lifecycle-spanning risk process aligned to ISO 31000.
Annex A	The normative annex of 42001 listing 38 controls across nine domains; the AI governance control selection framework.
High-Level Structure (HLS)	The shared clause structure used by all modern ISO management system standards, enabling integrated implementation across 42001, 27001, and 9001.
Presumption of conformity	The legal mechanism whereby demonstrating conformity with a harmonized standard is accepted as presumptive compliance with the corresponding EU AI Act requirements.
AI system impact assessment (A.6.1)	Pre-deployment documented assessment of how an AI system may affect people, required for consequential systems under 42001 Annex A.
Certification scope	The defined boundary of which AI systems and activities are covered by an organization's 42001 certification; narrow scope creates false assurance risk.
ISO/IEC 22989:2022	The AI vocabulary and concepts standard; provides shared terminology used across the JTC 1/SC 42 standards family.
Distributional shift	An AI-specific risk where model performance degrades because real-world inputs diverge from the training data distribution; addressed in ISO/IEC 23894.
Statement of Applicability (SoA)	Document listing which Annex A controls apply to an organization's AIMS, which are excluded, and the justification for each exclusion; mirrors the 27001 SoA.

Quick Revision Checklist

- ISO/IEC 42001:2023 is a management system standard — it specifies how to govern AI activities, not what AI outputs should look like.
- 42001 uses the HLS, enabling integration with 27001 and 9001 in a unified management system with shared clauses and combined audits.
- Annex A lists 38 controls across nine domains; organizations select applicable controls and document exclusions in a Statement of Applicability.
- Key Annex A controls: A.6.1 (impact assessment), A.7.4 (training data validation), A.8.4 (output monitoring), A.9.1 (human oversight), A.2.4 (supplier controls).
- ISO/IEC 23894:2023 provides the AI risk management methodology that gives operational content to 42001's risk clauses.
- ISO/IEC 22989:2022 is the vocabulary standard; 24029 series covers neural network robustness assessment.
- EU AI Act harmonized standards will create a presumption of conformity path; 42001 is the primary management system standard feeding into them.
- Certification scope is a critical decision — narrow scope excluding third-party AI integrations creates false assurance.
- Laws bind; frameworks guide; standards specify how to implement. The EU AI Act is law; NIST AI RMF 1.0 is a framework; ISO/IEC 42001 is a standard.
- Organizations with mature NIST CSF 2.0 or AI RMF implementations have strong foundations for 42001 certification.

10 Exam-Based MCQs — ISO AI Standards

Test yourself after reading. These questions mirror the scenario-heavy, distractor-rich style of the CompTIA SecAI+ exam. Read every explanation including for questions you answered correctly.

Q1. Scenario: A healthcare AI company is implementing ISO/IEC 42001. The defined AIMS scope covers all internally developed AI systems used for diagnostic support. A third-party AI billing optimization tool — integrated via API and making autonomous billing decisions affecting patient accounts — is excluded from the certification scope because it is a vendor product. A healthcare AI company is preparing for ISO/IEC 42001 certification. Its AIMS scope covers internally developed diagnostic AI models. A third-party AI-powered billing optimization tool integrated into the company's systems is excluded from scope. Which risk does this create?

- A) The company cannot receive ISO/IEC 42001 certification unless all software systems are in scope
- B) The certification provides assurance over the most visible internal models while potentially excluding third-party AI that creates material risk — a false assurance gap
- C) The third-party tool is not subject to any governance obligation because it is a vendor product
- D) The Stage 1 documentation review will automatically flag the scope exclusion as a major nonconformity

Answer: B **Explanation:** B is correct: certification scope is a definitional choice, and an AIMS that excludes third-party AI integrations from scope may provide false assurance — the organization is certified

for its internal processes while material risks from third-party AI remain ungoverned. This is the core risk the task highlights. A is wrong: ISO/IEC 42001 does not require all software to be in scope; scope definition is the organization's decision, but consequences flow from narrow scoping. C is wrong: organizations have governance obligations for AI that affects their customers or operations regardless of whether it is internally or externally developed — supplier controls (A.2.4) apply. D is wrong: Stage 1 auditors review documentation for completeness against the defined scope, not whether the scope itself is appropriately broad.

Q2. Which ISO/IEC 42001:2023 Annex A control specifically requires an AI system impact assessment before deploying systems that may affect people?

- A) A.7.4 — Data validation for training datasets
- B) A.8.4 — Output monitoring and logging
- C) A.6.1 — AI system impact assessment
- D) A.9.1 — Human oversight design

Answer: C **Explanation:** C is correct: A.6.1 mandates AI system impact assessments before deploying systems that may affect people, covering potential harms, affected populations, harm likelihood and severity, and mitigation measures. This is one of the highest-exam-relevance controls in Annex A. A is wrong: A.7.4 covers data validation for training datasets — important for data quality but not the pre-deployment impact assessment control. B is wrong: A.8.4 covers monitoring and logging of model outputs post-deployment — a detective control, not a pre-deployment assessment requirement. D is wrong: A.9.1 covers human oversight design — ensuring humans can intervene in AI decisions — which is a distinct control from the impact assessment.

Q3. *Scenario:* An enterprise CISO is planning ISO/IEC 42001 implementation. The organization already holds ISO/IEC 27001 certification with a mature ISMS and established internal audit program covering information security controls. An enterprise has ISO/IEC 27001 certification and is now implementing ISO/IEC 42001. The CISO wants to understand how the two standards should relate. Which statement BEST reflects the correct integration approach?

- A) The 42001 AIMS must be built as a completely separate management system to maintain auditor independence
- B) ISO/IEC 42001 and 27001 share the High-Level Structure, enabling an integrated management system with shared clauses, combined internal audits, and a single risk management process
- C) ISO/IEC 27001 is a prerequisite for 42001 certification — organizations must be 27001-certified before 42001 certification is available
- D) 42001 replaces the need for 27001 for organizations whose primary business is AI

Answer: B **Explanation:** B is correct: both standards use the High-Level Structure (HLS), specifically designed to enable integrated management systems. Organizations can share clause 6 (planning/risk), clause 7 (support), clause 9 (performance evaluation), and clause 10 (improvement) activities, conduct combined internal audits, and maintain a single documented risk management process — avoiding duplication. A is wrong: the HLS exists precisely to prevent the need for parallel systems; auditor independence does not require separate management systems. C is wrong: there is no prerequisite

relationship — 42001 certification is available to any qualifying organization regardless of 27001 status. D is wrong: 42001 covers AI management; 27001 covers information security broadly — AI security is a subset of information security, and both remain relevant for AI-focused organizations.

Q4. What does ISO/IEC 23894:2023 specifically address that ISO/IEC 42001:2023 references but does not itself prescribe?

- A) AI certification requirements for third-party certification bodies
- B) Detailed AI risk management methodology covering AI-specific risks such as distributional shift, adversarial inputs, and emergent behavior across the full AI lifecycle
- C) The vocabulary and terminology definitions used across the JTC 1/SC 42 family of standards
- D) Requirements for neural network robustness assessment

Answer: B **Explanation:** B is correct: ISO/IEC 23894 provides the detailed AI risk management methodology that 42001 references in its planning and operation requirements but does not itself prescribe. 23894 covers AI-specific risk categories (distributional shift, adversarial inputs, emergent behavior, training data quality, interpretability failures, human-AI interaction risks) and provides a lifecycle-spanning risk process aligned to ISO 31000. A is wrong: certification body requirements are covered by ISO/IEC 17021 and accreditation body standards, not 23894. C is wrong: ISO/IEC 22989:2022 is the vocabulary standard. D is wrong: ISO/IEC 24029 (parts 1 and 2) covers neural network robustness assessment.

Q5. Under the EU AI Act framework, what benefit does an AI provider gain by demonstrating conformity with published harmonized standards derived from ISO/IEC JTC 1/SC 42 work?

- A) Exemption from all EU AI Act obligations for the duration of the certification period
- B) A presumption of conformity with the Act requirements corresponding to those standards, simplifying the compliance demonstration path
- C) Automatic inclusion in the EU AI Act regulatory sandbox program
- D) Immunity from GDPR obligations that overlap with AI Act requirements

Answer: B **Explanation:** B is correct: the EU AI Act's harmonized standards mechanism — mirroring CE marking and GDPR compliance paths — allows providers demonstrating conformity with published harmonized standards to benefit from a legal presumption of conformity with the corresponding Act requirements. This means the certification does the compliance demonstration work rather than requiring a bespoke case. A is wrong: conformity with harmonized standards is not a general exemption from Act obligations; it is a conformity demonstration mechanism for specific requirements. C is wrong: regulatory sandbox participation is a separate program for innovation testing with no direct link to harmonized standard conformity. D is wrong: GDPR obligations are independent of AI Act obligations and AI certifications; no AI Act mechanism creates GDPR immunity.

Q6. Which clause of ISO/IEC 42001 requires organizations to manage AI procurement and third-party AI supplier relationships?

- A) Clause 4 — Context of the organization

- B) Clause 5 — Leadership
- C) Annex A.2.4 — Procurement and suppliers, within clause 8 Operation
- D) Annex A.6.1 — AI system impact assessment

Answer: C **Explanation:** C is correct: Annex A.2.4 addresses procurement and supplier controls for AI — requiring that third-party AI components and services are assessed before integration and managed throughout their lifecycle. This is operationally part of clause 8 (Operation). A is wrong: clause 4 covers organizational context and AIMS scope definition. B is wrong: clause 5 covers leadership commitment and AI policy governance. D is wrong: A.6.1 covers impact assessments for AI systems affecting people — related but distinct from procurement controls.

Q7. ISO/IEC 22989:2022 plays which role within the JTC 1/SC 42 AI standards family?

- A) It specifies requirements for AI management systems, enabling third-party certification
- B) It provides vocabulary and terminology definitions used consistently across all other JTC 1/SC 42 standards
- C) It provides AI risk management guidance aligned to ISO 31000
- D) It specifies assessment methods for neural network robustness

Answer: B **Explanation:** B is correct: ISO/IEC 22989:2022 is the AI concepts and terminology standard — the vocabulary document ensuring consistent interpretation of AI terms across all JTC 1/SC 42 standards and in international AI governance discourse. A is wrong: that is ISO/IEC 42001:2023. C is wrong: that is ISO/IEC 23894:2023. D is wrong: that is the ISO/IEC 24029 series.

Q8. A governance practitioner is preparing a Statement of Applicability for an ISO/IEC 42001 implementation. What does this document contain?

- A) The organization's AI policy statement signed by top management
- B) A list of all AI systems in the organization with their risk classification
- C) A record of which Annex A controls are applicable to the organization's AIMS, which are excluded, and the justification for each exclusion
- D) The results of the most recent management review meeting

Answer: C **Explanation:** C is correct: the Statement of Applicability (SoA) identifies which of the 38 Annex A controls apply to the organization's AIMS, which are excluded, and documents the justification for each exclusion. This mirrors the SoA mechanism in ISO/IEC 27001 exactly. A is wrong: the AI policy is a separate governance document required by clause 5. B is wrong: an AI system inventory is a separate asset management document, not the SoA. D is wrong: management review results are a clause 9.3 output, not the SoA.

Q9. Which of the following BEST distinguishes the legal status of ISO/IEC 42001:2023 from the EU AI Act?

- A) ISO/IEC 42001 is binding for organizations in EU member states; the EU AI Act applies only to non-EU AI providers

- B) Both are voluntary frameworks that organizations adopt for market positioning without legal obligation
- C) ISO/IEC 42001 is a voluntary standard with no direct legal penalty for non-adoption; the EU AI Act is binding law imposing regulatory liability and financial penalties for covered organizations
- D) The EU AI Act specifies management system requirements; ISO/IEC 42001 specifies prohibited AI use cases

Answer: C **Explanation:** C is correct: this is the fundamental law-vs-standard distinction. ISO/IEC 42001 is voluntary — organizations implement it for market access, procurement requirements, or competitive positioning, not because failure to certify creates direct legal liability. The EU AI Act is binding EU law — non-compliance by covered organizations creates regulatory liability, market access restrictions for high-risk AI systems, and financial penalties. A is wrong: this inverts both descriptions. B is wrong: the EU AI Act is not voluntary — it is binding law. D is wrong: this also inverts the descriptions.

Q10. Scenario: A governance consultant reviewing an organization's ISO/IEC 42001 AIMS documentation finds that the internal audit program tests only whether required policies and procedures exist as documented. No audit steps test whether controls are actually operating — for example, no sample review of impact assessment records or supplier assessment evidence. The Stage 2 certification audit is scheduled in 90 days. A practitioner discovers that an organization's internal audit program for its ISO/IEC 42001 AIMS tests only whether required documentation exists — not whether controls are operating in practice. A Stage 2 certification audit is scheduled in 90 days. What is the most significant risk?

- A) The Stage 1 documentary review will identify this gap and delay the entire certification timeline by 12 months
- B) The Stage 2 auditor will test whether AIMS controls are effectively implemented and maintained, likely identifying a major nonconformity that blocks certification if controls are not actually operating
- C) This is not a significant risk because Stage 2 auditors do not test operational evidence — they rely on the Stage 1 review
- D) The organization should immediately withdraw its certification application to avoid regulatory scrutiny

Answer: B **Explanation:** B is correct: ISO/IEC 42001 clause 9.2 requires internal audits to determine whether the AIMS 'is effectively implemented and maintained' — not just whether documentation exists. A Stage 2 audit tests both documentation and operational evidence (sample testing of whether impact assessments were actually conducted, whether supplier assessments were completed before AI procurement, whether audit logs show ongoing monitoring). Controls that exist on paper but are not operating in practice generate major nonconformities that block certification. A is wrong: Stage 1 reviews documentation completeness; an internal audit program gap may not be visible at Stage 1. C is wrong: Stage 2 is specifically designed to test operational implementation. D is wrong: the appropriate response is to fix the internal audit program and conduct proper operational audits before Stage 2, not to withdraw.